

PROTECCIÓN Y SEGURIDAD

SISTEMAS OPERATIVOS

DEPARTAMENTO CIENCIAS DE LA COMPUTACIÓN

FACYT-UC

PROF.PhD. MIRELLA HERRERA

Introducción

Un sistema informático ofrece servicios a usuarios humanos en el seno de una sociedad u organización. Algunos tipos de servicios son:

- Gestión de información (p.ej. transacciones financieras, archivos personales, etc.)
- Control de otras actividades (p.ej. procesos industriales, control de tráfico, etc.)
- Servicios empotrados en un aparato (p.ej. automóviles, robots...)

En muchos casos es cuestión de vida o muerte garantizar que el sistema informático funcione correctamente

Los recursos del sistema informático son limitados: hay un costo inherente a su utilización (tarifas o impuestos a los usuarios)

En toda sociedad u organización humana existen restricciones de uso de la información: derechos de intimidad, información que es sujeto de propiedad; etc. En tales casos es necesario restringir el acceso a la información del sistema

Objetivos

- Garantizar la integridad, disponibilidad y privacidad de la información contenida en un sistema informático
- Permitir la distinción de clases de usuarios, con diferentes autorizaciones sobre el uso de los recursos del sistema

La seguridad informática abarca: modos de trabajo de las personas, dispositivos físicos de seguridad, seguridad interna de la máquina y el sistema operativo, entre otros.

- **Seguridad externa:** referente a las instalaciones del sistema informático y al acceso de personas al sistema y su información.

Contempla estas dos áreas:

- Seguridad física de las instalaciones. Incluye medidas de prevención o recuperación de siniestros, y control de acceso al sistema.
 - Seguridad operacional. Políticas y mecanismos de seguridad tales como niveles de autorización o responsabilidad, métodos de acceso, protocolos de comunicación...
- **Seguridad interna:** se refiere a la circuitería del sistema, o a los asuntos de seguridad del sistema operativo

Fundamentos

Seguridad: considera el entorno externo dentro del cual opera el sistema. Concepto amplio que incluye aspectos físicos. P.ej. Quién puede acceder a una ubicación

Protección: es estrictamente un problema interno. Mecanismos que articula el sistema operativo para proteger información, usuarios y procesos entre otros...

Responde a : ¿Cómo se proporciona un acceso controlado a los programas y datos almacenados en un sistema?

Distinción entre políticas y mecanismos -> flexibilidad

- **Políticas (lo que se hará):** qué datos serán protegidos
- **Mecanismos (cómo se hará):** Deben especificar los controles que se van a implantar y los medios para hacerlos efectivos

Las políticas varían, los mecanismos deben ser lo bastante generales para abarcar un amplio abanico de políticas

Requisitos de Seguridad

Un sistema es seguro si sus recursos son utilizados y accedidos como se espera en todas las circunstancias

- **Problema:** intentar saltarse la protección de recursos
- **Requisitos de seguridad:** confidencialidad, integridad y disponibilidad de la información

Las violaciones de seguridad pueden ser:

- **Accidentales:** fáciles de tratar
- **Intencionadas:**
 - lectura no autorizada a datos (viola la confidencialidad)
 - modificación no autorizada (viola la integridad)
 - destrucción (viola la disponibilidad)

Requisitos de Seguridad

Se pueden tomar medidas de seguridad a 3 niveles:

- **Físico:** el lugar donde se encuentra el sistema debe estar protegido físicamente
- **Humano:** autorización cuidadosa a los usuarios
- **Sistema Operativo:** identificación

Identificación: identifica programas, procesos y usuarios

¿cómo? combinación de los siguientes conjuntos de elementos:

- posesión de un objeto (tarjeta, llave,...)
- atributo del usuario (huella dactilar, firma,...)
- conocimiento del usuario (password, username)

Contraseñas

La seguridad depende de quién pueda acceder → autenticación del usuario

- EL problema de la contraseña o password consiste en mantenerlos en secreto

Las contraseñas pueden ser:

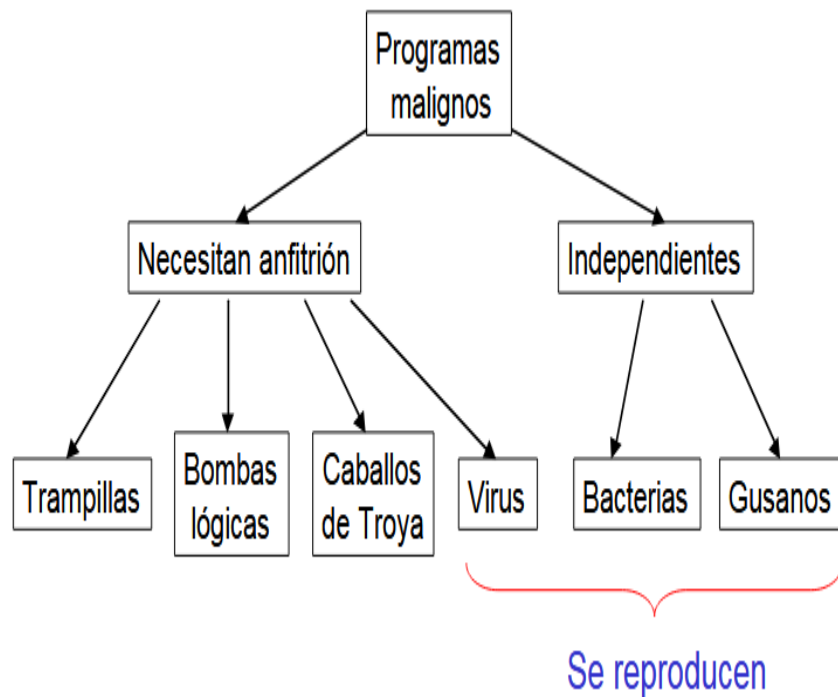
- **generadas por el sistema:** difíciles de recordar
- **seleccionadas por el usuario:** fáciles de adivinar
- Formas comunes de conocer una contraseña: conocer al usuario o tener información de él para intentar todas las posibles combinaciones de letras, números y otros caracteres (crypt)
- La lista de contraseñas de un sistema puede ser:
 - **privada:** acceso denegado a los usuarios
 - **pública:** se tiene acceso pero su contenido está codificado

Técnicas de Intrusión

Objetivo de los intrusos: obtener el acceso a un sistema o aumentar el conjunto de privilegios

- **Hacker:** talentos informáticos que entran al sistema por el placer de recopilar información que utilizan si la necesitan
- **Cracker:** acceden, y presumen de ello, a los sistemas para los que no tienen autorización. Suelen cometer daños irreversibles o irreparables en el sistema

!Cuidado! Ambos son ilegales



Técnicas para mejorar la seguridad

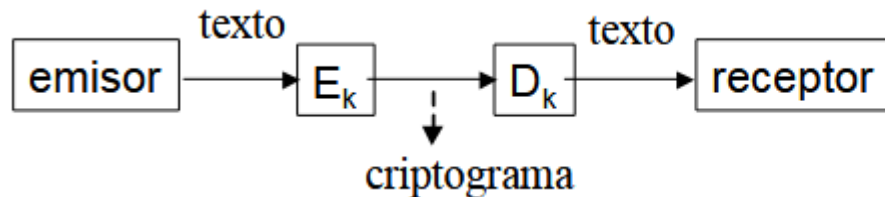
1. Monitorización de amenazas: comprobar si se intenta violar la seguridad del sistema -> buscar patrones de actividad sospechosos
2. Revisión de la información (auditoría):
 - Se registra el tiempo, usuario y tipo de todos los accesos a un objeto del sistema y si la operación tuvo o no éxito (archivo log)
 - Una vez que la seguridad se ha violado, esta información sirve para:
 - determinar cómo y cuándo ocurrió el problema y el daño producido
 - recuperarse del ataque
 - desarrollar una seguridad mejor

Técnicas para mejorar la seguridad

3. Explorar periódicamente distintos aspectos del sistema para evitar los ataques:

- claves cortas o fáciles
- programas no autorizados en directorios del sistema
- procesos no esperados de larga duración
- inapropiada protección de directorios/archivos
- cambios de tamaño en programas del sistema
- programas con acceso para cambiar SUID no autorizados

4. Proteger los datos mediante encriptación (sobre todo de la información transmitida por la red, los passwords, etc.)



E: algoritmo encriptación
D: algoritmo desencriptación
K: llave o llaves para cada aplicación

Técnicas para mejorar la seguridad

El experto en seguridad, Gene Spafford, dijo:

“El único sistema auténticamente seguro es el que está desconectado, desenchufado, y empaquetado en un recipiente hermético de titanio, guardado en un bunker de hormigón, rodeado de gas nervioso y custodiado por guardias muy bien armados y magníficamente pagados. E incluso así, yo no me jugaría la vida por él”

Conclusión: Un sistema es tan seguro como lo sea la gente que accede a él

Protección

Un sistema es una colección de procesos y objetos (hardware o software)

Cada objeto tiene:

- Un nombre único que lo identifica
- Un conjunto de operaciones para acceder a él
- Ejemplos: CPU – ejecutar /semáforo - wait, signal /archivo - leer, escribir, ejecutar, ...

Problema de protección: asegurar que cada objeto es accedido correctamente y sólo por aquellos procesos que lo tienen permitido

Dominios de Protección

Dominio de protección: define un conjunto de objetos junto con sus derechos de acceso { <nombre_objeto>, cjto_derechos_acceso> }

Derecho de acceso: permiso para realizar una operación sobre un objeto

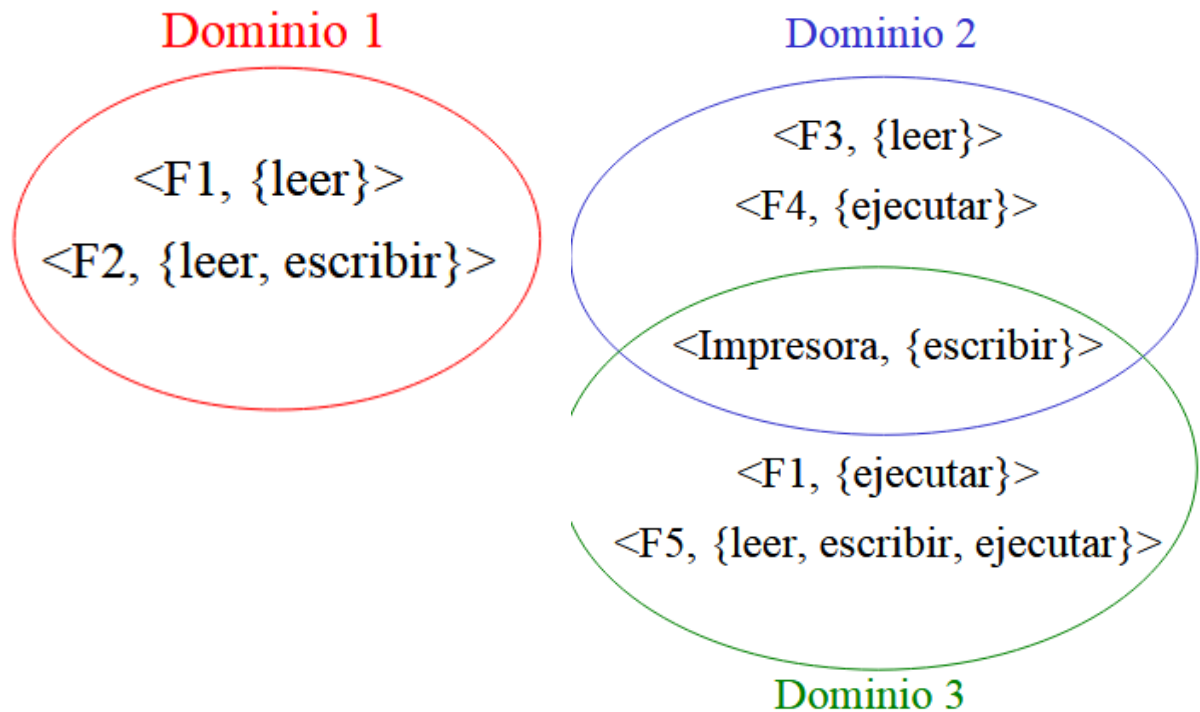
Un proceso se ejecuta dentro de un dominio.

La **asociación proceso-dominio** puede ser:

- **Estática:** el conjunto de objetos disponibles para un proceso es fijo durante la vida del proceso
- **Dinámica:** cambio de dominio durante la ejecución del proceso

Dominios de Protección

Los dominios no tienen porqué ser disjuntos. Ej. D2 y D3
Un objeto se puede encontrar en más de un dominio con derechos distintos. Ej. F1 en D1 y en D3



Dominios de Protección

¿Qué entidades pueden determinar un dominio?

- **Cada usuario:** el conjunto de objetos accesibles depende de la identidad del usuario. Ejemplo, Unix
- **Cada proceso:** el conjunto de objetos accesibles depende de la identidad del proceso
- **Cada procedimiento:** el conjunto de objetos accesibles se corresponde con sus variables locales

Ejemplos:

- Modo dual de operación -> solo, insuficiente
- **Unix:** los dominios se asocian con el uid. Los cambios de dominios se realizan a través del uid efectivo, son temporales y los proporciona el Sistema de Archivos

Protección en UNIX

En UNIX solo existen tres dominios de protección (propietario, grupo y mundo)

Para cada dominio se permiten únicamente tres operaciones sobre un objeto: lectura (r), escritura (w) y ejecución (x)

Cada objeto tiene asociados dos bits extras para conceder permisos especiales: *setuid* y *setgid*

- Si SETUID activo UID efectivo = UID del propietario
- Si SETGID activo GID efectivo = GID del propietario
- Si SETUID y SETGID están inactivos, se mantiene la identidad efectiva

Reglas de protección

- Si UID efectivo= UID del propietario se utiliza el dominio del propietario
- Si GID efectivo= GID del propietario se utiliza el dominio de grupo
- En caso contrario se utiliza el último dominio

Matriz de Acceso

Es el modelo que nos proporciona un mecanismo apropiado para especificar distintas políticas, y definir e implementar un control estricto (tanto para asociación estática como dinámica)

Elementos de la matriz de acceso:

- Filas -> Dominios
- Columnas-> Objetos
- Celdas -> Derechos de acceso

Matriz de Acceso

Objeto Dominio	F1	F2	F3	F4	F5	Impr.
D1	leer	leer escribir				
D2			leer	ejecutar		escribir
D3	ejecutar				leer escribir ejecutar	

Matriz de Acceso

Se pueden incluir los dominios como objetos para indicar el cambio entre dominios (conmutación)

Igualmente, cada entrada de la matriz puede incluirse como un objeto más a proteger

Objeto Dominio	F1	F2	F3	F5	Impres.	D1	D2	D3
D1	leer propiet.	leer escribir					Conmutar	
D2			leer*		escr			.
D3	eje.			leer escr. ejec.			Conmutar Control	

Matriz de Acceso

Problemas:

- Matriz de gran tamaño -> no cabe en MP
- Difícil agrupar dominios u objetos

Implementación: matriz dispersa

- **Almacenarla por filas:** lista de control de acceso (ACL) asociada a cada objeto. Cada entrada (ACE) define un dominio y unos permisos
- **Almacenarla por columnas:** capacidades (capabilities) asociadas a cada dominio (p). Permisos para acceder a objetos desde ese dominio

Las ACL son las más utilizadas

Listas de Control de Acceso

Listas de acceso para objetos (ACL): almacena la matriz por columnas. Asocia a cada objeto una lista ordenada de pares <dominio, conjunto_derechos>

- **Ventaja:**

- Fácil agrupar dominios y fáciles de crear y mantener

- **Problema:**

- Saber para un dominio dado, su conjunto de <objeto, conjunto_derechos>.
- No son buenas si el sistema es grande y está muy solicitado: las ACL se vuelven muy grandes y sus operaciones lentas

Implementación para un sistema de archivos:

Se asocia a cada archivo una lista de control de acceso

- En un bloque o en un archivo de sistema

Se guarda referencia a lista

- En entrada de directorio y/o en el nodo-i

El propietario del archivo puede manipular su lista. El SO comprueba la lista por cada acceso a un archivo



	Arch1	Arch 2	Arch 3
D1	Leer Escribir		Ejecutar
D2	Leer	Leer Escribir	
D3		Escribir	Ejecutar Leer

Archivo1: {(D1, [Leer, Escribir]), (D2, [Leer])}

Archivo2: {(D2, [Leer, Escribir]), (D3, [Escribir])}

Archivo3: {(D1, [Ejecutar]), (D3, [Ejecutar, Leer])}

Listas de Capacidades / Habilidades

Listas de Capacidades: Almacena la matriz por filas. Asocia a cada dominio una lista ordenada de pares <objeto, conjunto_derechos>

- Cada elemento se denomina capacidad
- Las listas de capacidades deben protegerse por el SO

Idea: Organizar los derechos de acceso por sujeto

Capacidad: entidad software asociada a un objeto que encapsula:

- La referencia al propio objeto
- Las operaciones realizables sobre el mismo

¡Los objetos nunca hacen referencia al propio objeto, sino a su capacidad!

- Los derechos
- Cada proceso recibe el conjunto de capacidades asociadas a los objetos que puede manipular
- Sólo puede acceder a cada objeto mediante su capacidad
- Si no dispone de la capacidad para un objeto: ¡no sabe ni de su existencia!

Listas de Capacidades / Habilidades

La Lista de capacidades debe ser gestionada por el sistema operativo

Operaciones soportadas:

- Crear un objeto (devuelve una capacidad al objeto)
- Duplicar una capacidad
- Restringir los derechos en una capacidad
- Eliminar una capacidad
- Pasar una capacidad como argumento a una llamada
- Copiar un objeto y su capacidad
- Destruir un objeto y su capacidad
- Transferir una capacidad a otro proceso

Sobre la capacidad, se pueden aplicar todas las operaciones que se aplican sobre el objeto

Un administrador por cada tipo de capacidad

Listas de Capacidades / Habilidades

Problema de transferir capacidades entre procesos:

¿Cómo revocar derechos?

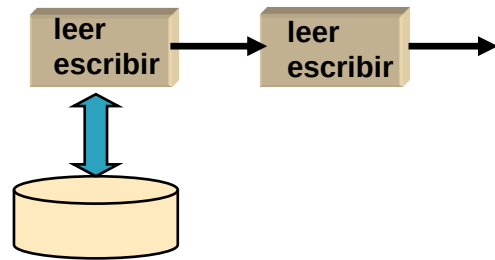
Revocación de permisos:

- Lista encadenada de capacidades
- Puntero indirecto
- Claves asociadas a los objetos

Listas de Capacidades / Habilidades

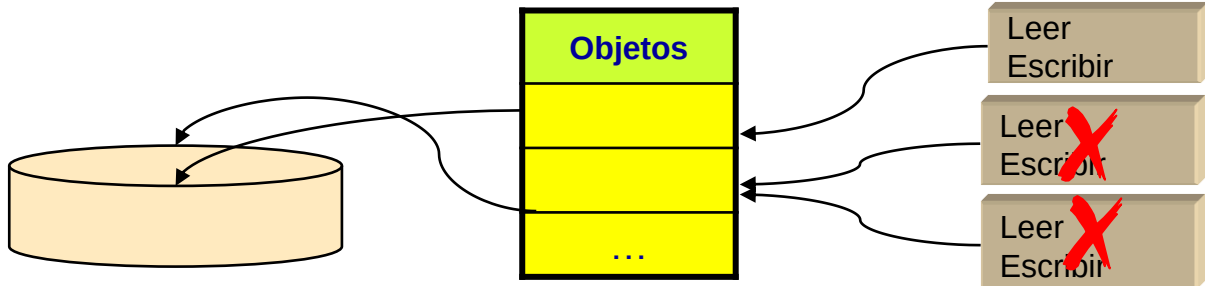
- **Lista encadenada de capacidades**

- Todas las copias de una capacidad enlazadas entre sí
- Así se pueden localizar para revocar permisos



- **Puntero indirecto**

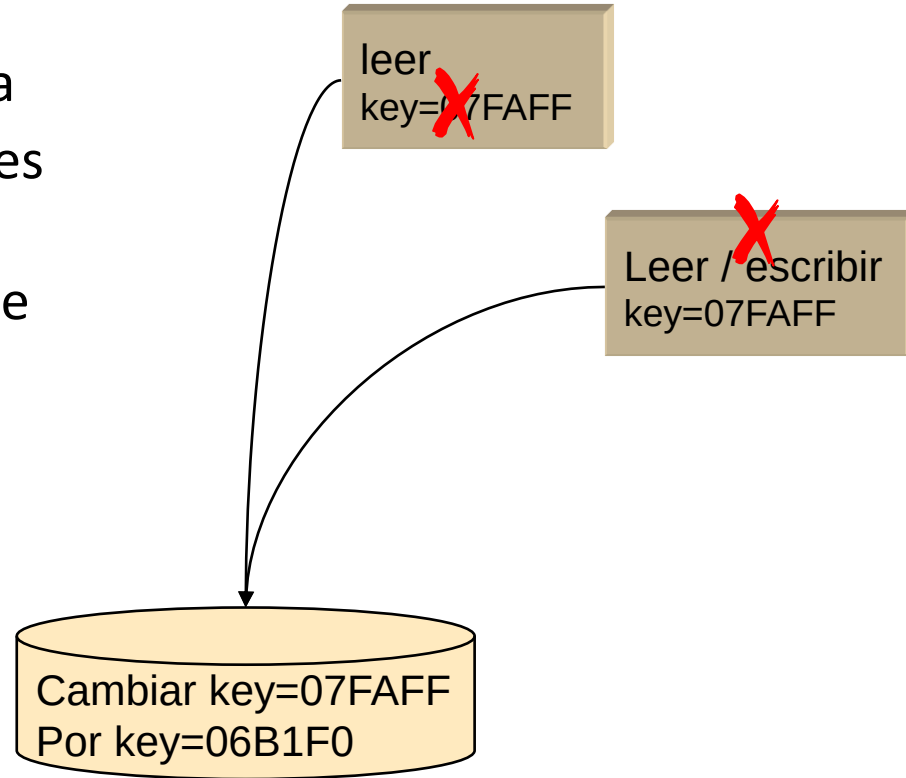
- Capacidades no hacen referencia al objeto, sino a un apuntador a éste
- Para revocar derechos, basta anular dicha referencia
- Se revocan todas las capacidades generadas a partir de esa referencia



Listas de Capacidades / Habilidades

Claves asociadas a los objetos

- Asocia a cada objeto una clave única
- Esta clave se copia en las capacidades generadas para dicho objeto
- En cada acceso, SO compara clave de objeto con clave de capacidad
- Si no coinciden, se deniega la operación
- Para revocar todas las capacidades basta con cambiar clave



Cerrojos-Llaves

Cada objeto tiene una lista de patrones de bits únicos (cerrojos), y cada dominio otra lista (llaves)

- Un proceso en un dominio puede acceder a un objeto si tiene una llave que se corresponde con uno de los cerrojos del objeto

Revocación de derechos

Es necesario revocar derechos a objetos compartidos en sistemas con un mecanismo dinámico de protección

Distintos aspectos de la revocación:

- Inmediata o retardada
- Selectiva o general: ¿afecta a un usuario o a todos?
- Parcial o total: ¿se eliminan todos los derechos?
- Temporal o permanente: ¿disponibles de nuevo?

Revocación con ACL: Es fácil e inmediata. Se busca en la lista los derechos a revocar y se eliminan

Revocación con LC: Difícil. Las capacidades están distribuidas por todo el sistema